

주 의 요 구 / 통 보

1. 제 목 : 개인정보 보호 등 정보보안 관리 불철저
2. 대상기관 : (주)캠코시설관리
3. 내 용 :

가. 업무개요

(주)캠코시설관리는 개인정보처리자로서 인사·노무 관련 내부 근로자 등의 개인정보를 수집하고 처리하는 업무를 수행하고 있다.

나. 관계 법령·내규 및 판단 기준

「개인정보 보호법」(이하 “법”이라 한다) 제29조에 따르면 개인정보 처리자는 개인정보가 분실·도난·유출·위조·변조 또는 훼손되지 아니하도록 내부 관리계획 수립 등 안정성 확보에 필요한 관리적·기술적 및 물리적 조치를 하여야 하고

법 제31조에 따르면 개인정보처리자는 개인정보의 처리에 관한 업무를 총괄해서 책임질 개인정보 보호책임자를 지정하여야 하고, 개인정보 보호책임자는 개인정보 보호 계획의 수립, 개인정보 처리 실태 및 관행의 정기적인 조사 및 개선, 개인정보 유출 및 오용·남용 방지를 위한 내부 통제시스템의 구축, 개인정보 보호 교육 계획의 수립 및 시행, 개인정보

파일의 보호 및 관리·감독 등의 업무를 수행하여야 한다.

또한, 「개인정보의 안정성 확보조치 기준」(개인정보보호위원회)²⁹⁾ 제4조에 따르면 내부 관리계획을 수립·시행함에 있어서 개인정보 보호책임자의 지정에 관한 사항, 개인정보 보호 책임자 및 개인정보 취급자의 역할 및 책임에 관한 사항 등 개인정보 보호를 위하여 필요한 사항을 제시하고 있으며, 개인정보 보호책임자는 접근권한 관리, 접속기록 보관 및 점검, 암호화 조치 등 내부 관리계획의 이행 실태를 연 1회 이상으로 점검·관리하여야 한다고 되어 있다.

따라서, (주)캠코시설관리는 내부 근로자 등의 개인정보를 처리하는 개인정보처리자로서 개인정보가 훼손되지 아니하도록 개인정보 보호 책임자를 지정하고 내부 관리계획을 수립하여 시행하는 등 개인정보 보호를 위한 적절한 안정성 확보 조치를 하여야 한다.

다. 감사결과 확인된 문제점

그런데 (주)캠코시설관리의 개인정보 보호 등 정보보안 관리 실태를 점검한 결과

(주)캠코시설관리는 내부 근로자 등의 개인정보를 수집하고 처리하기에 앞서 개인정보의 안정성 확보를 위해 [표 5]와 같은 관리적·기술적 및 물리적 조치를 취하고, 이를 반영한 내부 관리계획을 수립하고 그 이행실태를 정기적으로 점검·관리하여야 하는데도

29) 개인정보보호위원회고시 제2021-2호

[표 5] 개인정보의 안정성 확보 조치

구분	조치 사항
① 관리적 조치	▪ 개인정보의 안전한 처리를 위한 내부 관리계획의 수립·시행 (개인정보 보호책임자의 지정, 역할 및 책임에 관한 사항 등) ▪ 개인정보에 대한 접근 통제 및 접근 권한의 제한 조치
② 기술적 조치	▪ 개인정보를 안전하게 저장·전송할 수 있는 암호화 기술의 적용 또는 이에 상응하는 조치 ▪ 개인정보 침해사고 발생에 대응하기 위한 접속기록의 보관 및 위조·변조 방지를 위한 조치 ▪ 개인정보에 대한 보안프로그램의 설치 및 갱신
③ 물리적 조치	▪ 개인정보의 안전한 보관을 위한 보관시설의 마련 또는 잠금 장치의 설치 등 물리적 조치

※ 「개인정보 보호법 시행령」 제30조 및 「개인정보의 안정성 확보조치 기준」 참고

(주)캠코시설관리는 개인정보의 처리에 관한 업무를 총괄하는 개인정보 보호책임자를 경영지원본부장으로 지정하고, 정보보안을 위하여 PC보안 관련 안내 메일을 전 직원에게 매월 발송하고는 있으나

개인정보 보호책임자의 지정과 역할 및 책임에 관한 사항 등을 정한 개인정보 보호 내부 관리계획을 수립하여 시행하지 않고 있으며, 내부 관리계획의 이행 실태를 정기적으로 점검·관리하지도 않는 등 관련 법과 기준에서 제시한 ①관리적 조치를 하지 않고 있다.

또한, 회사 내부에 인사, 회계, 근태, 자산관리를 위한 서버용 PC를 2대 구축하여 내부 근로자 등의 개인정보를 처리하고 있음에도 불구하고 외부 침입을 방지하기 위한 ②기술적 조치가 되어 있지 않아

2021. 8. 5. 내부 서버용 PC 1대(인사, 회계, 근태)가 랜섬웨어³⁰⁾에 감염되어 저장된 개인정보 등이 사용할 수 없는 상태로 훼손되었으며,

30) 랜섬웨어(Ransomware)는 컴퓨터 시스템을 감염시켜 접근을 제한하고 일종의 몸값을 요구하는 악성 소프트웨어의 한 종류임

해당 일부터 같은 달 11.까지 약 7일간 인사, 회계, 근태시스템을 사용할 수 없어 관련 업무에 지장을 초래하였고, 랜섬웨어 복구 비용으로 5,280천 원을 지출하는 등 내부 서버용 PC에 대한 보안관리가 부실한 실정을 확인하였다.

또한, 외부 고객 개인정보를 처리하는 (주)캠코시설관리 홈페이지의 경우 구축 당시부터 외부 서버가상화서비스에 설치하였고, 내부 근로자 개인정보를 처리하는 업무시스템의 경우 인사, 회계시스템은 랜섬웨어 사고 이후 내부 서버용 PC에서 외부 서버가상화서비스로 이전하였으나

근태시스템에 대해서는 안전한 보관시설을 마련하지 못하고 적절한 ③물리적 조치를 취하지 않는 등 여전히 개인정보 침해사고 발생 가능성이 존재하는 실정이다.

이에 따라, (주)캠코시설관리는 내부 근로자 등의 개인정보의 안전한 관리를 위하여 개인정보 보호책임자를 지정할 뿐만 아니라 역할과 책임을 분명히 정하고 구체적인 개인정보 보호를 위한 내부 관리계획을 수립하여 그 이행 실태를 연 1회 이상 정기적으로 점검·관리하는 등 「개인정보의 안정성 확보조치 기준」에서 제시한 관리적·기술적 및 물리적 조치를 취할 필요가 있다.

[소관부점 의견] (주)캠코시설관리는 전산 전문인력이 부재하여 개인정보 보호를 위한 적절한 정보보안 조치가 부족하였으나, 향후 사내 정보 보안을 강화하는 방안을 마련하겠다고 답변하였다.

4. 조치할 사항

(주)캠코시설관리 대표이사는 랜섬웨어 사고를 예방하기 위하여 개인정보 보호 관련 업무를 철저히 하고, 향후 동일한 사례가 발생하지 않도록 직원 직무교육을 실시하시고, (주의)

개인정보 보호를 위한 내부 관리계획을 수립하고 이행 실태를 정기적으로 점검·관리하는 등 개인정보 보호의 안정성 확보를 위한 방안을 마련하시기 바랍니다. (통보)